

Security incident report

Section 1: Identify the network protocol involved in the incident

The network protocols identified during the investigation were DNS (Domain Name System) and HTTP (Hypertext Transfer Protocol).

The tcpdump log shows that the browser first sent a DNS request to resolve the IP address of yummyrecipesforme.com. After receiving the IP address from the DNS server, the browser established an HTTP connection to the website and sent an HTTP GET request. Later, the browser was redirected to greatrecipesforme.com, where another DNS lookup and HTTP connection occurred.

These protocols were used during the malicious redirection process that led users from the legitimate website to the malicious website.

Section 2: Document the incident

On the day of the incident, multiple customers reported that yummyrecipesforme.com prompted them to download a file to access free recipes. After running the downloaded file, users were redirected to a different website, greatrecipesforme.com, and reported performance issues on their computers.

The website owner was unable to access the administrative panel and contacted the hosting provider for assistance. During the investigation, cybersecurity analysts created a sandbox environment and monitored network activity using tcpdump.

Analysis of the tcpdump log showed that the browser successfully resolved the IP address of yummyrecipesforme.com through DNS and established an HTTP connection to the website. Shortly afterward, users were prompted to download an executable file. Additional analysis revealed that the executable

redirected users to greatrecipesforme.com through another DNS lookup and HTTP connection.

A review of the website source code found unauthorized JavaScript code that had been inserted into the website. The script prompted visitors to download the malicious executable file. Analysis determined that a former employee gained access to the administrative account through a brute force attack. The attacker successfully guessed the default administrator password, modified the website source code, and changed the account password to prevent legitimate access.

Evidence for this investigation included customer reports, tcpdump network traffic logs, website source code analysis, and findings from the cybersecurity investigation team.

Section 3: Recommend one remediation for brute force attacks

I recommend implementing multi-factor authentication (MFA) for administrative accounts.

Multi-factor authentication provides an additional layer of security by requiring users to verify their identity using a second authentication factor in addition to a password. Even if an attacker successfully guesses or obtains a password through a brute force attack, they would still need access to the second authentication factor to gain access to the account.

Implementing MFA would significantly reduce the risk of unauthorized access to administrative accounts and help prevent similar incidents in the future.